

Comment les distributions Linux s'adaptent-elles au «risque quantique» ?

Jérémy Viau-Trudel *Spécialiste DevSecOps*

André Gerges *Conseiller en recherche en cybersécurité et conformité*

Ikram Zahiri *Étudiante en génie logiciel*

Rencontre Linux Québec ■ mercredi 17 juin 17h

Québec - au Paccini de Ste-Foy

nouman/ty



Plan de la présentation

- Démonstration de l'algorithme de **Shor** (*brise encryption asymétrique*)
- Démonstration de l'algorithme de **Grover** (*affaiblit encryption symétrique*)
- Implémentation naive de Shor avec la librairie de qbit **Qiskit**
- Lancer une attaque à partir de l'ordinateur quantique d'IBM à Bromont via le portail **PINQ2**

Plan de la présentation

- 1. Au-delà de fragilité cryptographique : la réponses de l'industrie
- 2. La cryptographie, au coeur de l'infrastructure Linux
- 3. Déploiement des nouvelles composantes cryptographiques
- 4. Démo : vérification manuelle et CBOM de redhat/ubi10

Repenser la menace comme un risque

- Le « risque quantique » est un **déclencheur**, pas le sujet
- Il touche le **socle** de la cybersécurité : double risque, **négliger** ou se laisser **submerger** par le battage
- Les deux mènent au même endroit : l'**inaction**
- *Harvest Now, Decrypt Later* : l'exposition est **déjà présente**
- Le vrai enjeu : gérer la cryptographie comme un **actif**, vérifier sa chaîne d'approvisionnement
- Mêmes pratiques **cyber et DevSecOps**, niveau d'exigence relevé

C'est déjà normalisé

- Le risque se gère avec les **cadres existants** : NIST CSF 2.0, ISO 27005, FAIR
- Standards **NIST** (août 2024) : FIPS 203 **ML-KEM**, 204 **ML-DSA**, 205 **SLH-DSA**
- Relais internationaux : **BSI**, **ANSSI**, **ETSI** ; déclaration du **G7**
- Calendrier daté : dépréciation vers **2030**, retrait vers **2035**
- La question n'est plus « si » mais « **quand et comment** »

Et le Canada ?

- Le **Centre canadien pour la cybersécurité** s'appuie sur une variante du NIST CSF
- **Feuille de route** de migration ITSM.40.001 (en vigueur le 23 juin 2025)
- **Obligations contraignantes** pour le fédéral et ses sous-traitants, jusqu'au **CBOM**
- Guide aux organisations **ITSAP.00.017** et mesures d'**accompagnement**
- Et vous, **en êtes-vous ?**

L'inégalité de Mosca

- Un outil de décision : combien de temps reste-t-il ?
- **X** : durée pendant laquelle vos données doivent rester confidentielles
- **Y** : temps nécessaire pour migrer vers la cryptographie post-quantique
- **Z** : temps restant avant l'arrivée d'un CRQC (*Q-Day*)
- Si la somme $X + Y$ dépasse Z , l'exposition est **déjà là**
- Applicable à votre infrastructure, séance tenante

L'inégalité de Mosca

$$X + Y > Z$$

- **X** : durée de confidentialité requise
- **Y** : temps de migration
- **Z** : temps avant le *Q-Day*
- Si $X + Y$ dépasse Z : vous êtes **déjà en retard**

Linux, infrastructure stratégique

- Linux n'est pas qu'un noyau : c'est l'infrastructure sur laquelle tourne le monde
- Marginal sur le bureau ; **dominant ou hégémonique** partout ailleurs
- Serveurs, cloud, conteneurs, supercalcul, mobile, IoT, automobile
- Pour un décideur : un **socle irremplaçable** qu'il faut entretenir, donc financer
- Le rôle de la cryptographie varie selon la catégorie d'usage
- Leitmotiv : qu'arriverait-il si on laissait ce socle sans entretien cryptographique ?

Six catégories d'usage, six importances stratégiques

Catégorie	Usage principal	Importance stratégique
Entreprises et HPC	Systèmes critiques, supercalcul	Très élevée (valeur, criticité)
Communautaires	Socle amont, web, bureau avancé	Élevée (amont de l'écosystème)
Conteneur (images)	Base d'images cloud-native	Maximale (centre de gravité actuel)
Mobile	Téléphones grand public	Maximale en volume (71 % Android)
IoT et embarqué	Appareils, routeurs, edge, auto	Élevée et croissante, diffuse
Spécialités notables	Hôtes de conteneurs immuables	Élevée (cloud-native moderne)

Distributions par secteur d'activité

Catégorie	Dominante	Challenger	Notable
Entreprises et HPC	RHEL	SLES	Ubuntu Pro
Communautaires	Debian	Fedora	Arch / openSUSE
Conteneur	Alpine	Debian-slim / UBI	Wolfi
Mobile	Android (AOSP)	postmarketOS	Ubuntu Touch
IoT et embarqué	Yocto	OpenWrt	Buildroot
Spécialités	Fedora CoreOS	Talos Linux	NixOS / Flatcar

Le flux upstream vers downstream

- Deux forces déterminent la vitesse d'adoption du PQC dans une distribution
- **Gouvernance** : qui décide (communauté, éditeur, hybride) et selon quel rythme
- **Modèle de publication** : rolling (immédiat) ou fixe/LTS (à la prochaine stable)
- La feuille de route PQC = $f(\text{briques amont} + \text{gouvernance} + \text{modèle de publication})$
- Question clé : **connaissez-vous** la feuille de route PQC de vos distributions ?
- Une journée de formation suffit pour couvrir l'essentiel du risque opérationnel

Illustration : la famille Red Hat

Amont : Fedora

- Communauté, Red Hat parrain ; semi-rolling
- Laboratoire d'innovation : intègre OpenSSL 3.5 en premier (Fedora 42/43)

Intermédiaire : CentOS Stream

- Rolling, amont direct de RHEL ; préfigure la prochaine stable RHEL

Stable : RHEL

- Éditeur Red Hat ; fixe, support long
- Intègre, valide, active le PQC **par défaut** dès RHEL 10.1

Héritiers : AlmaLinux, Rocky Linux, Oracle Linux

La cryptographie, au coeur de l'infrastructure Linux

Classes RHEL : Héritiers des binaires PQC

Les composantes cryptographiques qui comptent

- Toute la cryptographie d'une distribution repose sur un **petit nombre de briques amont**
- La posture PQC d'une image se lit d'abord dans la **version de ces briques**
- Le PQC n'est pas à inventer : il est **déjà livré**, il s'agit de l'activer et de le suivre
- **OpenSSL 3.5** et **OpenSSH 10**, c'est l'essentiel du chemin

Les composantes cryptographiques qui comptent

Catégorie	Usage principal	Exemple	Version PQC
Pile TLS générale	HTTPS, chiffrement	OpenSSL	3.5.0 (avr. 2025)
Accès à distance	SSH	OpenSSH	10.0 (avr. 2025)
Runtime cloud-native	microservices, Kubernetes	pile Go	1.24 (jan. 2025)
Pile TLS embarquée	IoT, routeurs	wolfSSL	v7.0
Pile TLS navigateurs	HTTPS (Chrome, Firefox)	BoringSSL / NSS	2024+
Crypto noyau Linux	opérations système	Linux kernel	travaux en cours

OpenSSL : versions et feuille de route PQC

Version	Fonctionnalités PQC	Statut
< 3.2	aucune	non supporté
3.2.x	via fournisseur OQS externe (liboqs)	contournement
3.5.0 (avr. 2025)	ML-KEM, ML-DSA, SLH-DSA natifs	disponible

Feuille de route

- X25519MLKEM768 : hybride KEM activé **par défaut** en TLS 1.3
- Prochains jalons : élargissement des signatures PQC, diffusion dans les distributions
- OpenSSL 3.5 est la cible de migration pour la majorité des distributions Linux

Maturité PQC des distributions

Distribution	Posture	Ce qui est livré
RHEL 10	Leader	TLS hybride (OpenSSL, GnuTLS, NSS) ; signature RPM ML-DS
SLES 16	Challenger	TLS hybride (OpenSSL, libgcrypt, NSS, Go) ; SSH PQC pas enc
Ubuntu	Tail	PQC natif avec 26.04 (avr. 2026) ; OQS disponible sur 24.04 LT

Famille Red Hat : posture PQC

Distribution	Posture	Ce qui est livré
RHEL 10.1	Leader	TLS hybride + signature RPM ML-DSA + politiques PQ
Fedora 42/43	Leader	OpenSSL 3.5 natif ; X25519MLKEM768 par défaut ; labo
CentOS Stream	Challenger	Rolling amont de RHEL ; reçoit le PQC avant la stable
AlmaLinux	Challenger	Clone RHEL 10 ; briques PQC sans signature ML-DSA p
Rocky Linux	Challenger	Quasi identique à AlmaLinux ; propre clé de signature
Oracle Linux	Challenger	Clone RHEL 10 ; propre clé de signature
Amazon Linux 2023	Challenger	Dérivé Fedora ; OpenSSL 3.2.2 + crypto-polices PQ

PQC - vérification manuelle et scan CBOM

Démo



github.com/noumanity/pqc-linux/demo

Merci de prendre au sérieux la *menace quantique* !

Questions ?



github.com/noumanity/pqc-linux